# TRASCRIZIONE INTEGRALE APPUNTI - RISK MANAGEMENT & NORMATIVE

Raccolta completa degli appunti manoscritti (Pagine 1 - 9)

## STARTING DEFINITIONS

**Probability:** is based on the ability to predict. That ability depends on the skills and knowledge regarding the causal chain that leads to an event. Probability makes it predictable.

**Risk:** High possibility of a harmful event occurring (probability).
**Proactivity:** Techniques and methodologies aimed at prevention. Proactivity is the foundation of Risk Management. If unpredictable then we aim to eliminate or mitigate consequences...

## INFORMATION & TAXONOMY

Risk prevention relies on data and information.

**Information** is described as structured aggregation of data which requires understanding. It's semantics and the network of data it aggregates.

**Taxonomy** is the hierarchical ordering of data within the context of information and its context of discourse. (Relationships between data)

**Uniqueness & Unity:** In data we have two fundamentals: Signifier, Meaning

- ↳ **Signifier:** is the external form.
- ↳ **Meaning:** is its content.

PAGINA 2

**Harmony:** World is ordered, links different elements and commits them from a single structure, finds its own composition and gives raise to beauty. ("monos" that means one)

**Kosmo:** Order and Beauty of the world, governed and interpretable by a conscious man.

**The Word:** Connective tissue that allows the world to be reflected in thought and communication making social unity possible.

→ No words → No thought and communication → No social unity.

**Signifier & Signified:**

- ↳ **Signifier:** is the physical form (sound that the mouth says).
- ↳ **Signified:** is the concept (representation of the book).

Thanks to the correlation between sound and concept, Comprehension occurs; so Denotation is crucial.

**Denotation:** The action by which a word works as a pointer to the single and agreed-upon meaning of a word by a group's shared social and cultural knowledge.

**Sense & Meaning:** Expressing emotions is another reason we communicate. Sense is the presentation, or the path your mind takes to get to the meaning.

**Dynamics of Communication:** The Talker uses the shared words of the group (The winner of / The loser of) and the listener extracts the meaning from the social context.

**Interpretation:** The communication level turns subjective. To comprehend a polysemic word (more meanings) asks for crucial context.

## ELEMENTS OF LAW / PENAL CODE - OMISSION & OFFENSE

**Omission:** The law sanctions the non-transition towards the required action.

- **Proper:** When inertia is the direct violation of a norm.
- **Improper:** When the mean to commit an offense is the lack of activity.
- **T factor:** Action for omission of the subject. ("muscular level")
- **K factor:** Conscious factor or psychic impulse of a subject.

**Causal Link:** First step to determine the subject's responsibility.

- T factor of the subject must be the cause of the fact.
- Excluded responsibility if other factors (other than T) could produce the fact on their own.

**Foundation of Guilt:** After confirming the subject committed the fact, we establish the K factor in which it was committed.

**Psychological element:** Was it committed with:

- **Intent (Dolo):** Foreseen result by the agent.
- **Fault (Colpa):** Not willed but caused through negligence, imprudence (ex. inexperience) or non-compliance with law.

**Elements of the Offense: What is Jus? PT. 3**

A fact constitutes an offense only if it falls within the **Typical fact**. To understand if it does we must consider:

- Typical fact as a model or template
- Historical fact as an instance of the model
- Relationship between historical and abstract model (subsumption)

We first clear the linguistic verification, checking the meaning of the historical fact to the one of the typical fact.

## CONCURRENCE OF CRIMES & JUSTIFICATIONS

**Concurrence of Crimes:**

- **Formal concurrence:** Commits multiple crimes with the same action.
- **Material concurrence:** Commits multiple crimes at different times.
- **Continuous offense:** Formal + material. Multiple crimes, even at different times, in execution of the same criminal design.
- **Concurrence of Crimes:** Same person commits multiple crimes.
- **Concurrence of Penal norms:** When a single action falls in the description of multiple penal norms.
- **Concurrence of people in Crime:** Multiple people participate in the same crime. Each has to participate with T or K factor.

**Attempted Crimes** are different crimes compared to the consummated crimes.

**Justifications:**

- ↳ **Fortuitous event:** Unforeseeable event.
- ↳ **Forza maggiore:** Subject becomes a mechanism of the fact.
- ↳ **Physical constraint:** Being forced to act.
- ↳ **Consent of the entitled:** If given consent AND not an inalienable right (death).
- ↳ **Fulfillment of Duty:** Lack of coherence of legal system (Journalist report).
- ↳ **Legitimate defense:** Balance between aggressor sacrifice and victim protection, if without excess.
- ↳ **Necessity:** Necessity of saving themselves.

PAGINA 5

## GDPR & DATA PROTECTION

**Why GDPR is important?**

1. **Accountability:** They must demonstrate compliance at any time, so they must perform proactive Risk Management.
2. **Data as an asset:** They recognize personal data as an extension of the natural person.
3. **Empowerment of Subjects:** Giving the right to be forgotten (to delete data), and data portability to have the right to switch providers and move one's digital data.

**Principles for every Risk Assessment:**

- **Lawfulness, Fairness, Transparency:** No hidden processing.
- **Purpose limitation:** Data for purpose A can't be used for purpose B without consent.
- **Data minimization:** Collect only what is necessary.
- **Storage limitation:** Delete data when purpose is fulfilled.
- **Integrity and Confidentiality:** Prevent data breaches.

**International Data Transfer:**
The GDPR treats as international transfers all transfers from or to the outside of the European Economic Area (EEA).

**Conditions:**

1. **Adequacy:** Transfer allowed if the third country has been established by the European Commission as having an adequate level of protection.
2. **Appropriate safeguards:** In the absence of an adequacy decision, the transfer is possible if the Data Controller or Processor provides appropriate safeguards.
3. **Derogations:** Transfer allowed only in special cases like explicit consent, public interest, or performance of contract.

PAGINA 6

## CYBERSECURITY DIRECTIVES: NIS1 & NIS2

**Limitations of NIS1:**

- ↳ Different approaches from members.
- ↳ Uneven application of obligations.
- ↳ Fragmentation of the internal market.
- ↳ Lack of consistency in supervision.
- ↳ Many uncovered critical sectors.
- ↳ Reduced response capacity for major incidents (Covid...).

**NIS 2:** Systemic reform made in 2022 after Covid with many introductions:

1. **New Classification of regulated entities:** Eliminates OES / DSP and introduced: Essential entities and Important entities. Size-based, but small companies with high risk can be included as essential entities.
2. **Expansion of covered sectors:** Included sectors like: food sector, postal, waste management, chemical and medical device industries,...
3. **Risk Management obligations:** Mandating 10 minimum measures: incident management, supply chain security, vulnerability management, auth, encryption, business continuity...
4. **Structured 3-way phase notifications:** Early warning (24h) → Full notification (72h) → Final Report (within 1 month).
5. **Harmonized European sanctions regime:** Where Essential entities pay up to 10M € or 2% of global turnover, while Important entities pay up to 7M € or 1.4%.
6. **Advanced European Governance:** Strengthening CSIRT, EU-CyCLONe for large-scale risk management, EU coordinated vulnerability Disclosure, central role for ENISA.

## FORMULA MATEMATICA / APPUNTO SIMBOLICO (PAGINA 7)

$$( C_1^2 - C_1^2 ) / ( C_1^2 / C_1^2 ) = C_1^2 / C_1^2$$

PAGINA 8

## FRAMEWORK ISO 27005 (ZATTI)

Presents a simplified form where Risk Assessment is the sum of Identification, Analysis and Evaluation.

Is a guidance for managing information security risks in conformity with ISO 27001. It doesn't prescribe a specific methodology but rather a general framework applicable to any organization.

Promotes an iterative approach PDCA (Plan-Do-Check-Act), to ensure continuous improvement.

**Important Criteria to consider:**

- ↳ Risk evaluation criteria
- ↳ Impact criteria
- ↳ Risk Acceptance criteria

**Workflow:**

1. **Description of ISRA:** Define the context, where we decide the basic criteria, then identify, describe and prioritize risks.
2. **RA on assets:** Identification of assets: identify all available info on assets, creating the list of assets and of associated business processes.
3. **RA: Identification of Threats:** Study information on possible threats, creating a catalogue of threats, its source and type.
4. **RA: Identification of existing controls:** Check documentation of existing controls and Risk Treatment Plan (RTP). (abbiamo le difese e lo status implem)
5. **RA: Id. of vulnerabilities:** Cross-reference between previous Asset, Threat and existing controls, this creates a vulnerability list.
6. **RA: Id. of Consequences:** Evaluate possible impact on the triad CIA.
7. **RA: Risk estimation:** Take previous info and use qualitative or quantitative scales to categorize them.



## USE CASES & FRAMEWORK COMPARISON (ISO 27005, NIST, OCTAVE, EBIOS)

**Use cases: ISO 27005**
Let's start by defining context: We mention what we have in this context and then explore our objective of this analysis.

- **Risk Identification:** We start with Assets (what do we own and need to protect), then the threats (are they cyber and physical?). Next the vulnerability (Maybe some service in use can be hardware/software).
- **Risk Evaluation:** Is the impact of the calculated threat critical (breaks some of the CIA triad)? Does the prob. of the threat expected to change?
- **Risk Treatment:** Can we fix it? Maybe Retention, reduction, share, avoidance.

**NIST SP 800-53:**
It can't be used for organizational risk assessment, it focuses on technical infrastructure (federal information system).

- Prescriptive → no asset identification (context).
- Use it when IT infrastructure.

**OCTAVE:**
Information assets are its focus, it's designed to be self-directed.

> Establish criteria → Profile assets → Identify threats → Identify risks → Mitigate risks. (asset-centric)

**EBIOS:**
Focuses to identify Feared Events and Threat scenarios and focuses on how an attacker might attack. (Path)